

API SECURITY RISK ANALYSIS REPORT

30 JUNE 2026

Prepared by

Jonathan Patterson

JSONPlaceholder Public REST API



Table of Contents

Introduction	3
Objectives	3
Scope	3
Included.....	3
Excluded.....	3
Tools Used	4
Methodology.....	4
API Overview.....	4
Security Findings	5
Finding 1. Publicly Accessible Endpoints.....	5
Finding 2. Excessive Data Exposure	5
Finding 3. Missing Authentication.....	5
Finding 4. Missing Authorization Controls	5
Finding 5. No Visible Rate Limiting.....	5
Finding 6. Input Validation Could Not Be Confirmed	5
Risk Assessment Summary	6
Recommendations.....	6
Conclusion.....	6

Introduction

Application Programming Interfaces (APIs) are a fundamental component of modern web applications, mobile applications, and Software as a Service (SaaS) platforms. They enable communication between different systems and facilitate the exchange of data.

Because APIs frequently process sensitive information, they are attractive targets for attackers. Weak authentication, poor authorization controls, excessive data exposure, and insufficient request validation can lead to data breaches and service abuse.

This report presents a read only security assessment of the JSONPlaceholder demonstration API. The objective was to identify common API security risks using safe testing techniques while following ethical cybersecurity practices.

Objectives

The objective of this investigation was to:

- ♥ Analyse a publicly available REST API.
- ♥ Evaluate authentication and authorization mechanisms.
- ♥ Identify common API security risks.
- ♥ Assess the potential business impact of each risk.
- ♥ Recommend practical remediation strategies based on industry best practices.

Scope

This assessment was limited to publicly available endpoints provided by JSONPlaceholder. It was compiled with all the testing guidelines that were outlined/

Included

- ♥ Documentation review
- ♥ GET request analysis
- ♥ Response inspection
- ♥ Header analysis
- ♥ Security risk identification

Excluded

- ♥ Exploitation attempts
- ♥ Authentication bypass
- ♥ Denial of Service testing
- ♥ Vulnerability exploitation
- ♥ Any destructive or unauthorised testing



Tools Used

Tool	Purpose
Postman	API testing and request analysis
VS Code	Updating Github
Google Chrome Developer Tools	Response and header inspection
JSONPlaceholder	Public demonstration REST API
GitHub	Version control and project submission
Microsoft Word	Report documentation

Methodology

The following process was used during the assessment:

1. Reviewed the API documentation.
2. Identified publicly available endpoints.
3. Sent read only GET requests using Postman.
4. Examined API responses and returned data.
5. Inspected request and response headers.
6. Evaluated authentication and authorization requirements.
7. Identified potential security risks.
8. Classified each finding according to its severity.
9. Developed remediation recommendations.

API Overview

API Name

JSONPlaceholder

Base URL

<https://jsonplaceholder.typicode.com/>

Endpoints Tested

Endpoint	Purpose
/posts	Retrieve posts
/users	Retrieve user information
/comments	Retrieve comments
/albums	Retrieve albums

The API is intentionally designed for learning and testing purposes and does not contain real user information.

Security Findings

Finding 1. Publicly Accessible Endpoints

Observation

The tested endpoints were accessible without authentication or user verification.

Evidence

- ♥ GET /posts
- ♥ GET /users
- ♥ GET /comments
- ♥ GET /albums

Severity

High

Business Impact

In a production environment, unrestricted public access could allow attackers to collect sensitive information without authentication. Public endpoints increase the risk of data scraping, reconnaissance, and information disclosure.

Recommendation

Require authentication using secure mechanisms such as OAuth 2.0, JWT bearer tokens, or API keys before granting access to protected resources.

Finding 2. Excessive Data Exposure

Observation

The /users endpoint returned information including:

- ♥ Name
- ♥ Username
- ♥ Email
- ♥ Address
- ♥ Phone number
- ♥ Website
- ♥ Company information

Severity

Medium

Business Impact

Returning more information than necessary increases privacy risks and provides attackers with useful information for phishing or social engineering attacks.

Recommendation

Only expose information required by the client application and apply the principle of least privilege.

Finding 3. Missing Authentication

Observation

Requests were processed successfully without requiring API keys, bearer tokens, and user authentication

Severity

High

Business Impact

Without authentication controls, unauthorised users may gain unrestricted access to sensitive resources in a production environment.

Recommendation

Require secure authentication for all protected API endpoints.

Finding 4. Missing Authorization Controls

Observation

There are no visible access control mechanisms were identified.

The API returned information for all available users without verifying ownership.

Severity

Medium

Business Impact

Poor authorization controls may allow users to access resources belonging to other users, resulting in information disclosure.

Recommendation

Poor authorization controls may allow users to access resources belonging to other users, resulting in information disclosure.

Finding 5. No Visible Rate Limiting

Observation

No rate limiting headers such as X RateLimit Limit and Retry After were observed during testing.

Severity

Low

Business Impact

Finding 6. Input Validation Could Not Be Confirmed

Observation

Because JSONPlaceholder is a demonstration API, server side validation could not be verified.

Severity

Low

Business Impact

Without request throttling, attackers could automate requests and overload production services.

Recommendation

Implement request throttling and rate limiting to reduce abuse.

Poor input validation in production environments may increase the risk of injection attacks and malformed requests.

Recommendation

Validate all user supplied input on the server and reject invalid requests.

Risk Assessment Summary

Finding	Severity	Business Impact
Public endpoints	High	Unauthorised information access
Excessive data exposure	Medium	Privacy and information disclosure
Missing authentication	High	Unauthorised access
Missing authorization	Medium	Cross user data exposure
No visible rate limiting	Low	Service abuse
Input validation not confirmed	Low	Potential injection risks

Recommendations

The following recommendations would improve the security posture of a production API:

- ♥ Require authentication for protected endpoints.
- ♥ Implement Role Based Access Control.
- ♥ Return only the minimum amount of data required.
- ♥ Implement request rate limiting.
- ♥ Validate all client supplied input.
- ♥ Regularly review API logs for suspicious activity.
- ♥ Follow the OWASP API Security Top 10 guidelines.
- ♥ Perform periodic API security assessments.

Conclusion

This assessment demonstrated the process of conducting a professional API security review using a public demonstration API. Although JSONPlaceholder is intentionally designed for testing purposes, the assessment highlighted several security considerations that would require attention in a production environment.

The findings focused on authentication, authorization, excessive data exposure, rate limiting, and input validation. Implementing the recommended controls would strengthen API security and reduce the likelihood of unauthorised access or misuse.

This exercise provided me with practical experience in API security analysis and demonstrated the importance of secure API design within modern SaaS applications.